

Hands-On-Learning: Software Supply Chain Security: SBOM Generation and Vulnerability Analysis with Syft and Gype

Learning Objective

By the end of this activity, learners will be able to:

- Install and configure Syft and Gype tools for software supply chain analysis
 - Generate comprehensive Software Bills of Materials (SBOMs) in industry-standard formats (SPDX, CycloneDX)
 - Perform vulnerability scanning on container images and software components
-

- Analyze vulnerability scan results to identify critical security risks and prioritize remediation efforts
 - Develop practical remediation strategies for managing vulnerable dependencies
 - Apply SBOM and vulnerability data to improve organizational supply chain security posture
-

Description

This practical workshop introduces learners to essential software supply chain security tools using Anchore's open-source Syft and Gype. Students will work with a real container image to generate detailed SBOMs, identify vulnerable components, and develop actionable remediation strategies. The lab demonstrates how organizations can achieve visibility into their software dependencies and proactively manage supply chain risks through automated scanning and analysis.

Structure of the Activity

Tools used

Syft (SBOM generation tool by Anchore)

Grype (vulnerability scanner by Anchore)

Command line interface (Linux/macOS/Windows)

Sample container image for analysis

Scenario

Your organization is implementing a comprehensive software supply chain security program in response to recent high-profile attacks like SolarWinds and Log4j. As a security engineer, you've been tasked with evaluating a containerized application that your development team wants to deploy to production. You need to create a complete Software Bill of Materials (SBOM) to understand all components and dependencies, scan for known vulnerabilities, and provide actionable recommendations for securing the application before deployment. This analysis will establish the baseline visibility and processes needed to meet new regulatory compliance requirements while protecting against supply chain attacks.

Objective

Use Syft to generate comprehensive SBOMs and Gype to identify vulnerabilities in a sample container image, then develop prioritized remediation strategies based on risk assessment and business impact.



Instructions for learners

1 Install Syft and Gype Tools

Open your terminal or command prompt

Install Syft using the official installation script:

```
curl -sSfL  
https://raw.githubusercontent.com/anchore/syft/main/install.sh |  
sh -s -- -b /usr/local/bin
```

Install Grype using the official installation script:

```
curl -sSfL  
https://raw.githubusercontent.com/anchore/grype/main/install.sh |  
sh -s -- -b /usr/local/bin
```

Verify installations by checking versions:

```
syft --version
```

```
grype --version
```

Note: On Windows, download the appropriate binaries from the GitHub releases page

2 Generate SBOM with Multiple Formats

Create SBOMs for a sample vulnerable container image in different formats:

```
syft docker.io/vulnerables/web-dvwa:latest -o json --file dvwa-sbom.json
```

```
syft docker.io/vulnerables/web-dvwa:latest -o spdx-json --file dvwa-sbom-spdx.json
```

```
syft docker.io/vulnerables/web-dvwa:latest -o cyclonedx-json --file dvwa-sbom-cyclonedx.json
```

Examine the generated SBOM files to understand the structure and metadata

Count the total number of packages discovered:

```
cat dvwa-sbom.json | grep -c '"name":'
```

3 Perform Comprehensive Vulnerability Scanning

Scan the container image directly with Gype:

```
gype docker.io/vulnerables/web-dvwa:latest
```

```
gype docker.io/vulnerables/web-dvwa:latest -o json --file dvwa-  
vulnerabilities.json
```

```
gype docker.io/vulnerables/web-dvwa:latest -o cyclonedx --file dvwa-  
vuln-cyclonedx.xml
```

Alternatively, scan using the previously generated SBOM (faster method):

```
grype sbom:dvwa-sbom.json -o json --file dvwa-vuln-from-sbom.json
```

Compare scan times between direct image scanning and SBOM-based scanning

4 Analyze and Prioritize Vulnerability Findings

Review the vulnerability scan results and categorize by severity:

```
grype docker.io/vulnerables/web-dvwa:latest | grep -E  
"(Critical|High|Medium|Low)" | sort | uniq -c
```

```
grype docker.io/vulnerables/web-dvwa:latest | grep -E "(Critical|High)"
```


Analyze key vulnerability metrics:

Total number of vulnerabilities found

Breakdown by severity (Critical, High, Medium, Low)

Number of vulnerabilities with available fixes

Packages with the most security issues

Identify the most critical vulnerabilities that require immediate attention

Document vulnerabilities that affect multiple packages
(transitive dependencies)

5 Develop Targeted Remediation Strategies

Based on your vulnerability analysis, create a prioritized remediation plan:

Immediate Actions (Critical/High severity with fixes available):

- List specific packages that need updating

- Document the fixed versions available

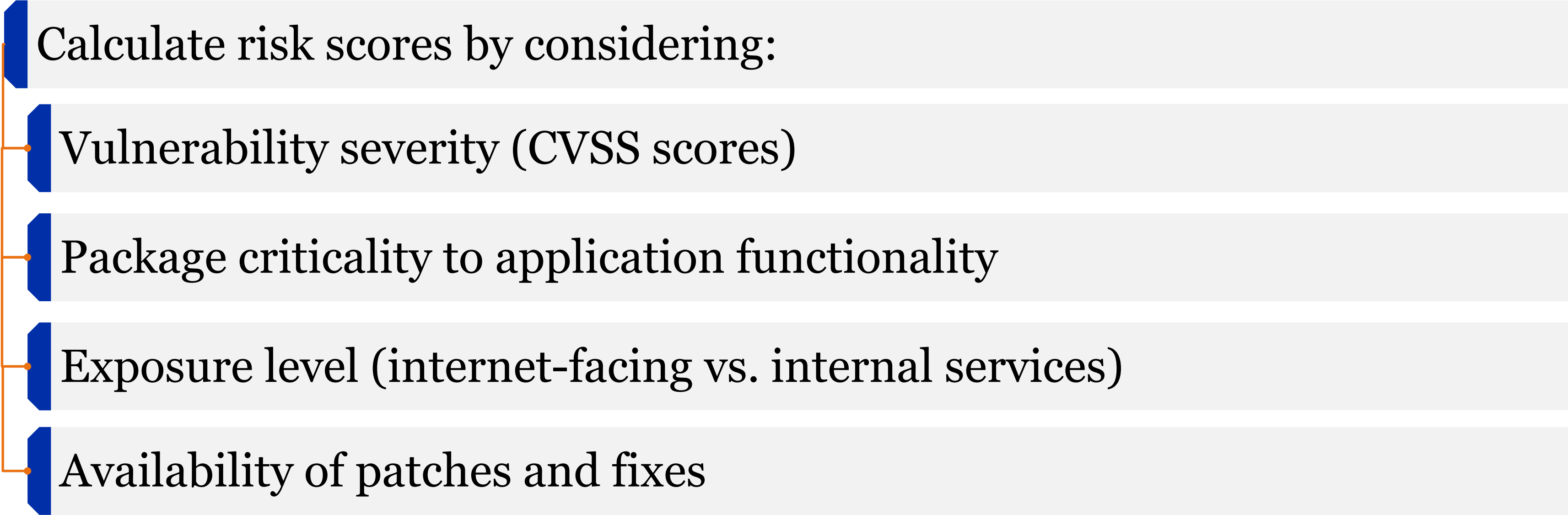
- Estimate update complexity and potential breaking changes

Short-term Actions (Medium severity and systemic issues):

- Identify base image updates needed
- Plan dependency review and update cycles
- Consider alternative packages for heavily vulnerable components

Long-term Strategy:

- Implement automated SBOM generation in CI/CD pipeline
- Establish continuous vulnerability monitoring
- Create policies for acceptable risk levels



Calculate risk scores by considering:

The diagram consists of a vertical orange line on the left. A blue bracket is attached to the top of this line. Five horizontal light gray bars extend to the right from the orange line. Each bar contains text. The first bar is connected to the blue bracket. The subsequent four bars are each connected to the orange line by a small orange dot.

Vulnerability severity (CVSS scores)

Package criticality to application functionality

Exposure level (internet-facing vs. internal services)

Availability of patches and fixes

6 Document Findings and Recommendations

Create a summary report including:

SBOM statistics (total packages, licenses, etc.)

Vulnerability assessment summary

Risk-prioritized remediation roadmap

Recommended security controls and monitoring

Save all generated files (SBOMs, vulnerability reports) for documentation

Take screenshots of key findings and scan results

Organize Information Following This Structure for Peer Review

1. Title Page:

Project title: "Supply Chain Security Analysis: SBOM and Vulnerability Assessment" Your name, date, container image analyzed

2. Requirement 1: SBOM Generation and Inventory Analysis

Document the total number of software components discovered

Compare the different SBOM formats (JSON, SPDX, CycloneDX) and their use cases

Analyze the package ecosystem (languages, package managers, licenses)

Identify any unexpected or concerning dependencies

3. Requirement 2: Vulnerability Assessment and Risk Analysis

Provide vulnerability statistics by severity level

Highlight the most critical vulnerabilities requiring immediate attention

Document vulnerabilities affecting multiple components

Include screenshots of key vulnerability scan outputs

Assess the overall security posture of the analyzed container

4. Requirement 3: Remediation Strategy and Security Recommendations

- Present a prioritized remediation roadmap with timelines
- Recommend specific package updates and version upgrades
- Suggest process improvements for ongoing supply chain security
- Propose implementation of continuous monitoring and automated scanning
- Include compliance considerations (regulatory requirements, industry standards)

Instructions for Documenting and Sharing the Project for Peer Review



1. Document the Project

Use word processing software to create your report.

Insert the diagram, map, screenshot, or image directly into your Word document, if available.

Ensure all sections of the project document structure are completed.

Proofread and edit your report for clarity and accuracy.



Share the Project

Save your report and presentation in PDF format.

Upload your documents to the “Peer Review” area in the course shell.

Provide a brief description of your project in the submission post.



Peer Review

Review the projects submitted by your peers.

Provide constructive feedback and comments on their work.

Additional Resources and References:

Syft Documentation: <https://github.com/anchore/syft>

Grype Documentation: <https://github.com/anchore/grype>

SPDX Specification: <https://spdx.dev/specifications/>

CycloneDX Specification: <https://cyclonedx.org/specification/overview/>

NIST SSDF (Secure Software Development Framework):
<https://csrc.nist.gov/Projects/ssdf>

CISA SBOM Resources: <https://www.cisa.gov/sbom>